Informe ejecutivo de seguridad de red

Análisis de eventos de seguridad, accesos y alertas — CICIDS2017

Periodo: 03/07/2017 – 07/07/2017 · **Generado:** 14/10/2026 20:31 · **Versión:** 1.0

Equipo 2 — Cybersecurity Data Analytics

1. Resumen ejecutivo

Se analizaron 2,827,562 flujos de red entre 03/07/2017 – 07/07/2017. El 19.68% (556,555) fue malicioso, repartido en 14 tipos de ataque. DoS Hulk es el más frecuente (41.3% de los ataques) y la familia DoS/DDoS concentra 68.2%. La hora 16:00 reúne 41.9% de los ataques, 70.3% son de bajo volumen y sus flujos duran ≈11 veces más que los benignos (mediana), por lo que las reglas de detección deben combinar variables y no depender solo del tamaño del flujo.

FLUJOS ANALIZADOS
2,827,562

FLUJOS DE ATAQUE
556,555

% TRÁFICO MALICIOSO
19.68%

TIPOS DE ATAQUE DETECTADOS
14

PESO DE DOS/DDOS
68.2%

ATAQUES DE BAJO VOLUMEN
70.3%

2. Metodología y fuente

Fuente: dataset_enriquecido_final.parquet (CICIDS2017, agregado y anonimizado). Pipeline: parquet enriquecido → agregados anónimos (pandas) → KPIs → gráficos (Plotly) → plantilla Jinja2 → HTML/PDF/DOCX. Validaciones automáticas: las sumas por etiqueta, día y protocolo coinciden con el total de flujos.

3. Resultados

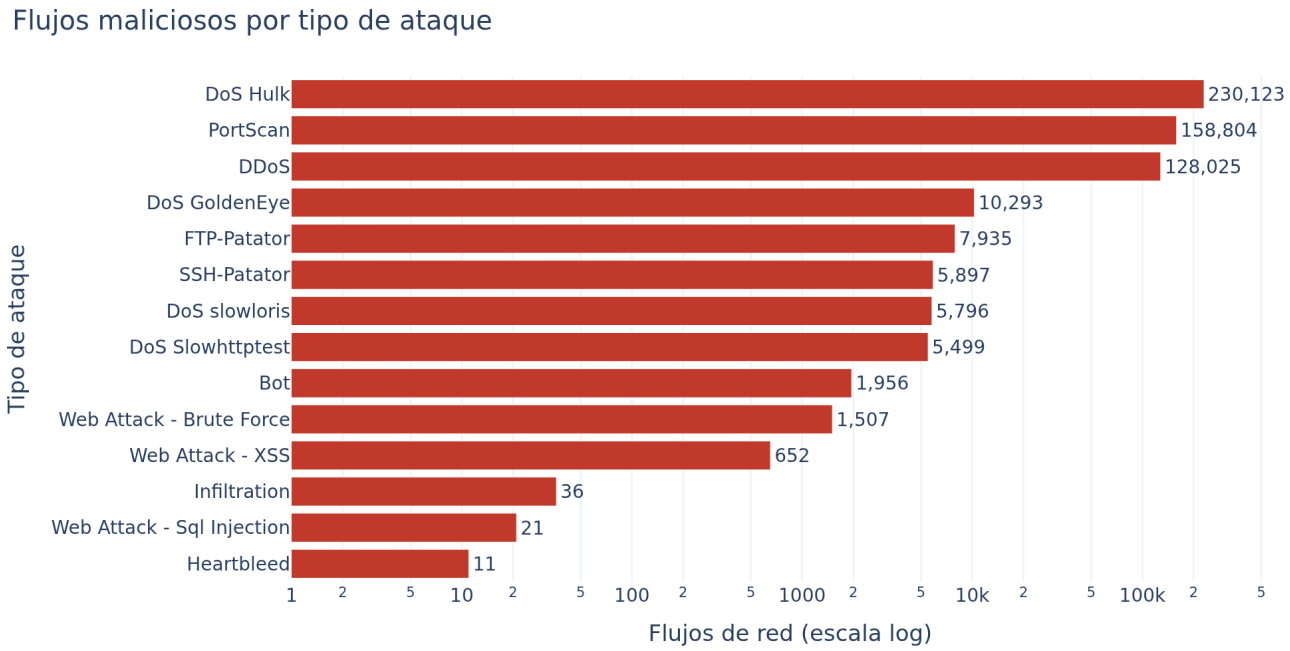


Figura 1. Ataques por tipo. Fuente: dataset_enriquecido_final.parquet (CICIDS2017, agregado y anonimizado).

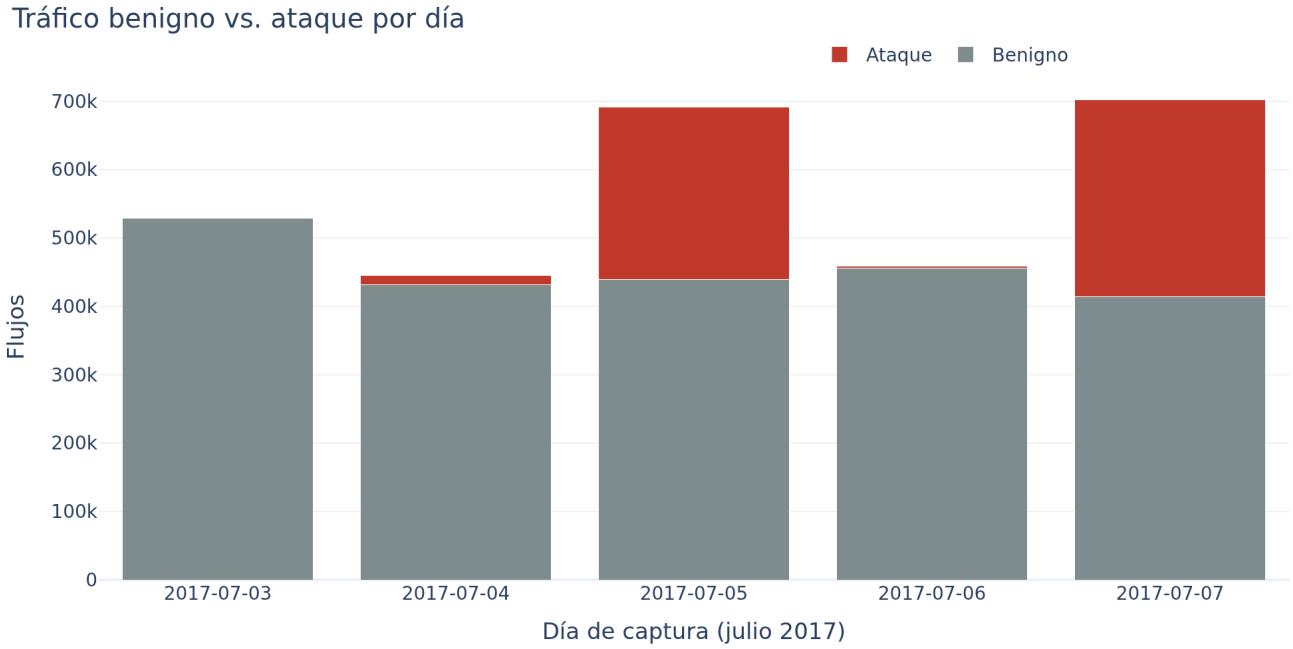


Figura 2. Ataques por día. Fuente: dataset_enriquecido_final.parquet (CICIDS2017, agregado y anonimizado).



Figura 3. Ataques por hora. Fuente: dataset_enriquecido_final.parquet (CICIDS2017, agregado y anonimizado).

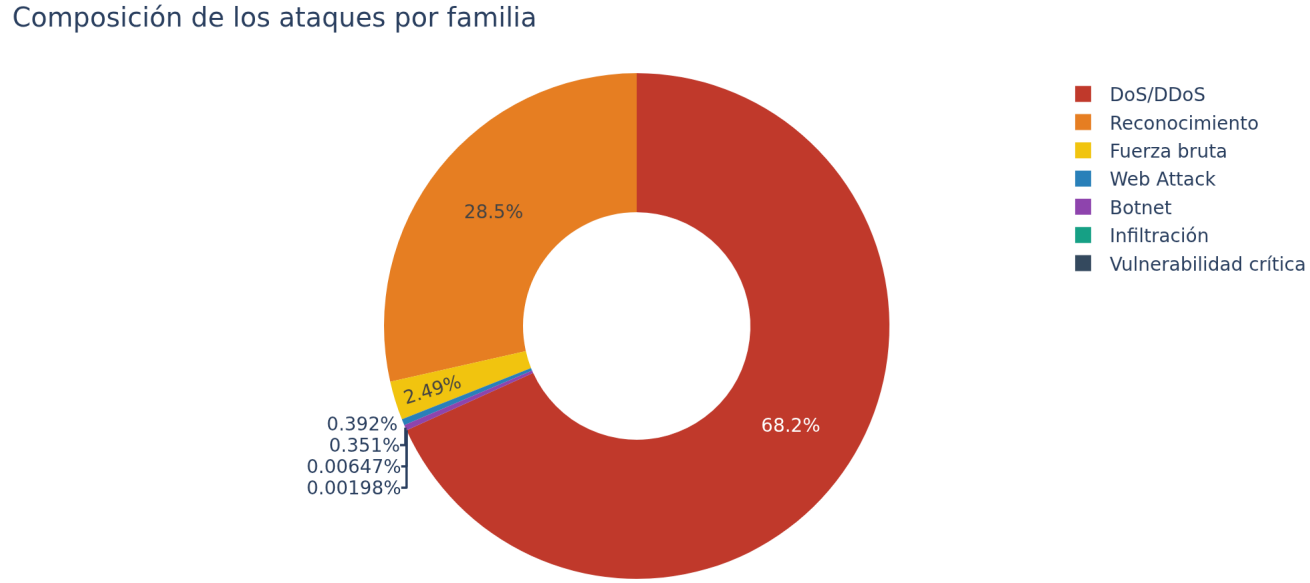


Figura 4. Familias de ataque. Fuente: dataset_enriquecido_final.parquet (CICIDS2017, agregado y anonimizado).

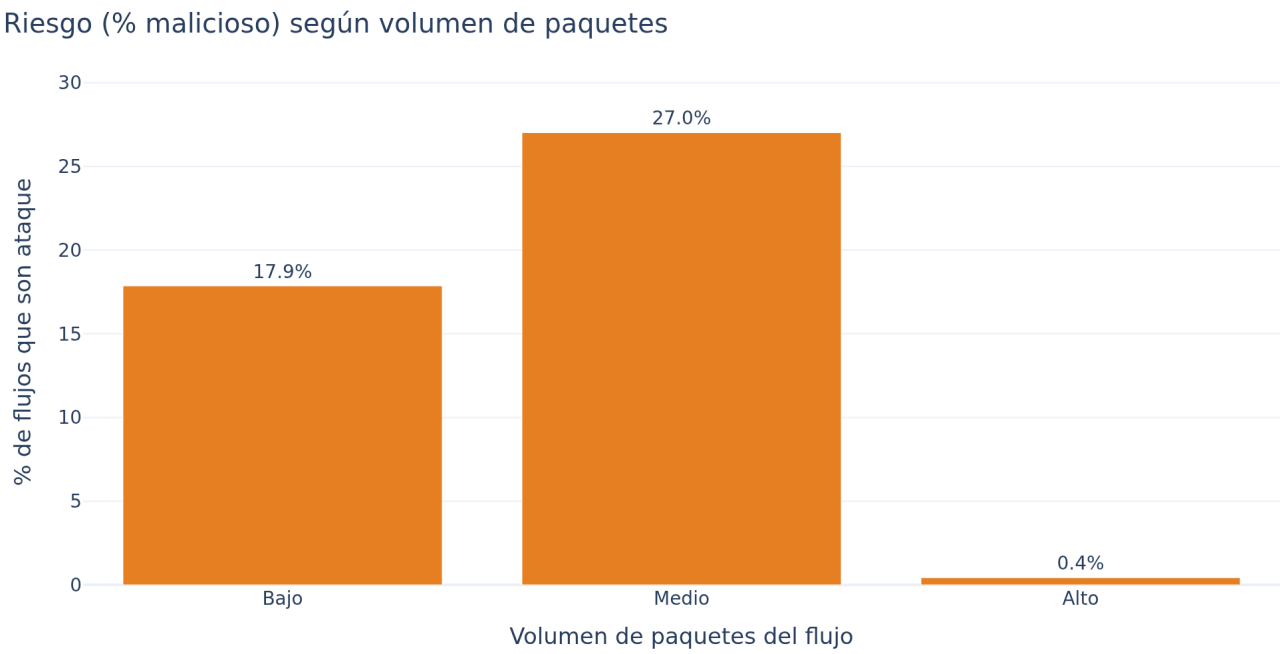


Figura 5. Riesgo por volumen de paquetes. Fuente: dataset_enriquecido_final.parquet (CICIDS2017, agregado y anonimizado).

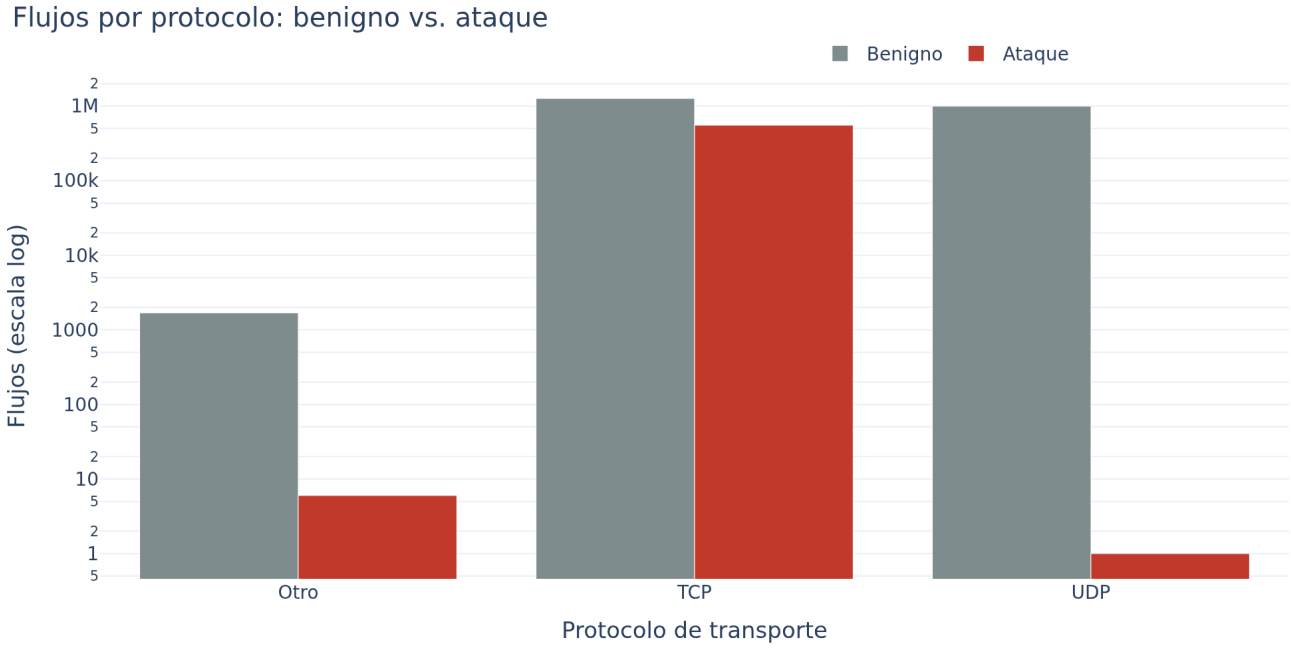


Figura 6. Flujos por protocolo. Fuente: dataset_enriquecido_final.parquet (CICIDS2017, agregado y anonimizado).

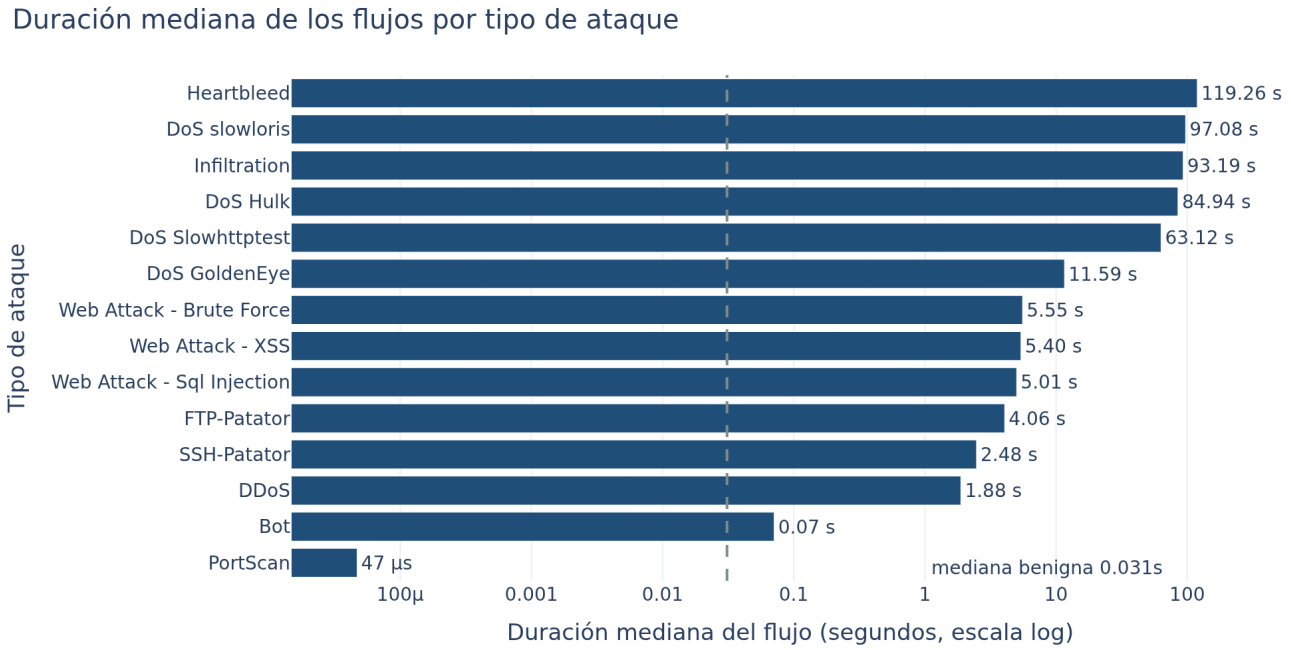


Figura 7. Duración mediana por tipo de ataque. Fuente: dataset_enriquecido_final.parquet (CICIDS2017, agregado y anonimizado).

Detalle por tipo de ataque

Tipo de ataque	Familia	Flujos	% de ataques	Duración mediana (s)
DoS Hulk	DoS/DDoS	230,123	41.35%	84.94
PortScan	Reconocimiento	158,804	28.53%	4.7e-05
DDoS	DoS/DDoS	128,025	23.00%	1.879
DoS GoldenEye	DoS/DDoS	10,293	1.85%	11.59
FTP-Patator	Fuerza bruta	7,935	1.43%	4.056
SSH-Patator	Fuerza bruta	5,897	1.06%	2.475
DoS slowloris	DoS/DDoS	5,796	1.04%	97.08
DoS Slowhttptest	DoS/DDoS	5,499	0.99%	63.12
Bot	Botnet	1,956	0.35%	0.07097
Web Attack - Brute Force	Web Attack	1,507	0.27%	5.552
Web Attack - XSS	Web Attack	652	0.12%	5.399
Infiltration	Infiltración	36	0.01%	93.19
Web Attack - Sql Injection	Web Attack	21	0.00%	5.006
Heartbleed	Vulnerabilidad crítica	11	0.00%	119.3

4. Hallazgos

1. DoS Hulk es el ataque más frecuente

Evidencia: 230,123 flujos, 41.3% de todos los ataques; la familia DoS/DDoS concentra 68.2%.

Interpretación: La amenaza dominante es la saturación de servicios web (denegación de servicio), no la intrusión silenciosa.

Impacto: Un solo patrón explica la mayoría de la carga maliciosa: mitigarlo reduce el riesgo de forma desproporcionada.

Decisión sugerida: Priorizar rate limiting y alertas de DoS sobre servicios HTTP.

Limitación: CICIDS2017 es tráfico de laboratorio: las proporciones no son extrapolables a una red productiva.

2. Los ataques se concentran en la hora 16:00

Evidencia: 233,292 flujos de ataque en esa hora (41.9% del total); solo 4 de 5 días presentan ataques y el día pico fue 2017-07-07 (288,785 ataques).

Interpretación: La actividad maliciosa llega en ventanas concentradas, no distribuida uniformemente.

Impacto: Una vigilancia uniforme desperdicia capacidad analítica fuera de las ventanas críticas.

Decisión sugerida: Reforzar monitoreo y guardia en las franjas de mayor incidencia.

Limitación: Las horas reflejan el calendario del experimento (un escenario por franja), no un patrón humano real.

3. Los ataques son mayormente flujos de bajo volumen de paquetes

Evidencia: 70.3% de los ataques tienen volumen 'Bajo'; en cambio 99.57% de los flujos de volumen 'Alto' son benignos.

Interpretación: El volumen alto por sí solo no indica ataque; los ataques son flujos pequeños y repetitivos.

Impacto: Reglas basadas solo en umbrales altos de volumen no detectarían la mayoría de los ataques.

Decisión sugerida: Combinar volumen con frecuencia, puerto destino y duración en las reglas de detección.

Limitación: El volumen está categorizado (Bajo/Medio/Alto): se pierde detalle fino.

4. Los flujos de ataque duran mucho más que los benignos

Evidencia: Duración mediana: 0.35 s en ataques vs 0.031 s en benignos (≈11 veces más). La excepción es PortScan, con flujos de microsegundos.

Interpretación: Los ataques de agotamiento (DoS lentos) mantienen conexiones abiertas; el escaneo, en cambio, es ráfaga muy corta.

Impacto: La duración separa dos comportamientos de amenaza distintos y sirve como variable de detección.

Decisión sugerida: Alertar por conexiones inusualmente largas y por ráfagas ultracortas masivas hacia muchos puertos.

Limitación: La mediana oculta la dispersión interna de cada tipo de ataque.

5. Casi todo el ataque viaja por TCP y apunta al puerto 80

Evidencia: 99.999% de los ataques usan TCP; el puerto 80 (HTTP) recibe 68.7% de ellos, seguido de FTP (21) y SSH (22).

Interpretación: La superficie de ataque expuesta es, sobre todo, el servicio web sobre TCP.

Impacto: Proteger ese servicio cubre la mayor parte del riesgo observado.

Decisión sugerida: Hardening y monitoreo específico del servicio web; restringir FTP/SSH si no son necesarios.

Limitación: El puerto destino no identifica al atacante; las IP no se publican por gobernanza (Guía 4).

5. Recomendaciones

#	Acción	Prioridad	Responsable	Plazo	KPI de seguimiento
1	Implementar rate limiting y detección de DoS en servicios HTTP	Alta	Equipo de infraestructura / seguridad	30 días	% de flujos DoS/DDoS bloqueados
2	Reforzar monitoreo en las franjas horarias de mayor incidencia	Alta	Analista SOC	15 días	Ataques detectados en hora pico / total
3	Reglas de detección multivariable (volumen + frecuencia + puerto + duración)	Media	Ingeniería de datos / ML	60 días	Tasa de detección sin aumentar falsos positivos
4	Restringir FTP/SSH y bloquear por intentos fallidos (fuerza bruta)	Media	Administración de sistemas	45 días	Intentos de fuerza bruta por día
5	Mantener este informe automatizado y versionado en GitHub	Baja	Equipo 2	Continuo	Informes generados sin intervención manual

6. Limitaciones y gobernanza

Dataset de laboratorio (CICIDS2017, 3–7 jul 2017): no representa una red productiva actual.

Desbalance de clases: ~80% benigno; Heartbleed (11), Infiltration (36) y SQL Injection (21) están muy poco representados.

Limpieza previa: se eliminaron 288,602 flujos sin etiqueta, 203 duplicados exactos y 2,978 flujos con valores inválidos (Infinity/NaN, rangos); quedan 2,827,562.

Las direcciones IP, flow_id y puertos de origen no se incluyen (minimización y seudonimización, Guía 4).

No se incluye análisis geoespacial (Guía 6): es una red de laboratorio sin coordenadas reales; el equivalente por segmento de red exigiría exponer IP.

Informe generado automáticamente desde el notebook Reporte_Automatizado.ipynb. Trazabilidad en metadata_informe.json.